

Assignment Week 7

Table of Contents

Laboratório de Segurança da Informação	2
--	---

Laboratório de Segurança da Informação

1. Identifique o tipo de ameaça ou vulnerabilidade correspondente aos seguintes cenários:

Vamos classificar cada situação para entender melhor os riscos envolvidos.

a. Perda do celular contendo credenciais para conexão ao servidor X

- **Tipo: Vulnerabilidade de Acesso e Perda de Dados.**
- **Explicação:** A perda física do dispositivo é um problema, mas a vulnerabilidade real reside no fato de as credenciais estarem armazenadas nele e poderem ser acessadas. Isso pode levar a um **acesso não autorizado** ao servidor X, comprometendo a segurança dos dados e sistemas.

b. Porta de conexão SSH aberta para todos

- **Tipo: Vulnerabilidade de Configuração de Rede e Acesso.**
- **Explicação:** O SSH (Secure Shell) é uma ferramenta poderosa para acesso remoto seguro. No entanto, deixá-lo "aberto para todos" significa que qualquer pessoa na internet pode tentar se conectar ao seu servidor. Isso expõe o sistema a **ataques de força bruta** (tentativas repetidas de adivinhar senhas) e a **exploração de vulnerabilidades** no próprio serviço SSH, permitindo acesso não autorizado.

c. Falha na carga dos UPSs no Datacenter

- **Tipo: Vulnerabilidade de Infraestrutura e Indisponibilidade.**
- **Explicação:** UPS (Uninterruptible Power Supply) são essenciais para manter os sistemas funcionando durante quedas de energia. Uma falha na carga significa que, em caso de interrupção elétrica, os servidores não terão energia de backup, resultando em **parada inesperada dos serviços**, **perda de dados** (se não houver desligamento seguro) e **indisponibilidade** crítica para a empresa.

d. Servidor com setores danificados

- **Tipo: Vulnerabilidade de Hardware e Integridade de Dados.**
- **Explicação:** Setores danificados em um disco rígido indicam falha iminente ou já existente do hardware. Isso representa um alto risco de **perda de dados, corrupção de arquivos e instabilidade do sistema operacional**. A integridade e a disponibilidade dos dados armazenados no servidor ficam seriamente comprometidas.

e. Uso de tarjetas NFC com informações básicas de identificação

- **Tipo: Vulnerabilidade de Privacidade e Engenharia Social.**
- **Explicação:** Embora as informações sejam "básicas", o uso de NFC (Near Field Communication) pode permitir que atacantes com equipamentos específicos leiam esses dados sem o seu conhecimento, apenas se aproximando. Isso pode levar à **exposição de informações pessoais**, que, mesmo básicas, podem ser usadas em ataques de **engenharia social** ou para **clonagem de identidade** em contextos específicos.

f. Servidores com protocolo ICMP aberto

- **Tipo: Vulnerabilidade de Configuração de Rede e Ataques de Negação de Serviço (DoS).**
- **Explicação:** O ICMP (Internet Control Message Protocol), usado para comandos como **ping**, quando totalmente aberto, pode ser explorado. Atacantes podem usá-lo para **reconhecimento de rede** (mapear a topologia e identificar hosts ativos) ou, mais perigosamente, para **ataques de negação de serviço (DoS)**, como o ataque Smurf, inundando o servidor com tráfego ICMP e tornando-o inacessível.

g. Falta de alteração de senhas por parte dos usuários

- **Tipo: Vulnerabilidade de Política de Segurança e Comprometimento de Contas.**
- **Explicação:** Senhas que nunca são alteradas aumentam exponencialmente o risco de serem comprometidas. Se uma senha for vazada em um incidente de segurança externo, descoberta por força bruta ou engenharia social, ela permanecerá válida

indefinidamente. Isso leva ao **acesso não autorizado** às contas dos usuários e aos sistemas da empresa, com potenciais **perdas financeiras, roubo de dados e danos à reputação**.

2. Explique o que é o ataque Smurf e comente sobre os três ataques mais conhecidos até o momento.

Vamos entender o Smurf e depois os ataques mais famosos!

O que é o ataque Smurf?

O ataque Smurf é um tipo de **ataque de negação de serviço (DoS - Denial of Service)** que visa sobrecarregar um sistema ou rede, tornando-o indisponível para seus usuários legítimos. Ele explora uma vulnerabilidade no protocolo ICMP (Internet Control Message Protocol), mais especificamente no comando **ping**.

Como funciona:

1. **Atacante:** Envia um grande número de pacotes ICMP (requisições de **ping**).
2. **Endereço de Origem Falsificado:** O atacante falsifica o endereço IP de origem desses pacotes, colocando o endereço IP da vítima (o alvo do ataque).
3. **Rede de Broadcast:** Os pacotes são enviados para o endereço de *broadcast* de uma rede intermediária (uma rede que permite que um pacote enviado para um endereço específico seja entregue a todos os hosts dessa rede).
4. **Amplificação:** Todos os hosts ativos nessa rede de broadcast recebem o pacote ICMP e, como o endereço de origem é o da vítima, eles respondem enviando um pacote ICMP de volta para a vítima.
5. **Inundação:** Se a rede de broadcast tiver muitos hosts e o atacante enviar muitos pacotes, a vítima será inundada por um volume massivo de respostas ICMP, sobrecarregando sua conexão de rede e seus recursos, tornando-a inacessível.

É como se alguém ligasse para uma central de atendimento, mas dissesse que o número de retorno é o da vítima, e a central ligasse de volta para a vítima repetidamente, sobrecarregando-a.

Três ataques mais conhecidos até o momento:

1. Phishing:

- **O que é:** É um ataque de engenharia social onde o atacante se disfarça de uma entidade confiável (banco, empresa de tecnologia, colega de trabalho) para enganar a vítima e fazê-la revelar informações sensíveis, como senhas, números de cartão de crédito ou dados pessoais.
- **Como funciona:** Geralmente ocorre por e-mail, mensagens de texto ou sites falsos que imitam os legítimos. A vítima é induzida a clicar em links maliciosos ou a inserir suas credenciais em páginas fraudulentas.
- **Por que é conhecido:** É extremamente comum e eficaz, pois explora a confiança e a desatenção humana, sendo a porta de entrada para muitos outros tipos de ataques.

2. Ransomware:

- **O que é:** É um tipo de malware (software malicioso) que, uma vez instalado no sistema da vítima, criptografa seus arquivos ou bloqueia o acesso ao sistema. Em seguida, exige um pagamento (resgate), geralmente em criptomoedas, para descriptografar os dados ou restaurar o acesso.
- **Como funciona:** Pode ser distribuído via e-mails de phishing, downloads maliciosos, exploração de vulnerabilidades em softwares ou redes.
- **Por que é conhecido:** Tem causado prejuízos bilionários a empresas e indivíduos em todo o mundo, paralisando operações críticas e resultando em perda de dados irrecuperável para muitas vítimas que se recusam ou não conseguem pagar o resgate.

3. DDoS (Distributed Denial of Service - Negação de Serviço Distribuída):

- **O que é:** É uma versão amplificada do ataque DoS, onde múltiplos sistemas comprometidos (chamados de "botnet" ou "zumbis") são usados para inundar o alvo com tráfego. Ao invés de um único atacante, são milhares ou milhões de máquinas atacando simultaneamente.
- **Como funciona:** Os atacantes controlam uma rede de computadores infectados (sem o conhecimento de seus proprietários) e os instruem a enviar um volume massivo de requisições ou dados para o alvo, sobrecarregando-o e tornando-o inacessível.

- **Por que é conhecido:** É uma das formas mais poderosas de ataque para derrubar sites, serviços online e infraestruturas de rede, sendo frequentemente usado por grupos hacktivistas, criminosos cibernéticos e até mesmo por nações.

3. Cenários práticos:

Agora, vamos aplicar o conhecimento em situações do dia a dia da TI.

a. Recentemente, você, como parte da equipe de TI, percebeu que apenas 30% dos usuários estão utilizando seu armazenamento em nuvem. Considerando que uma grande quantidade de informações é processada diariamente, que sugestão você daria aos usuários e que medidas adotaria para garantir sua implementação.

É uma situação comum, meu bem! O armazenamento em nuvem é uma ferramenta poderosa, mas a adoção depende muito da conscientização e do suporte.

Sugestões aos Usuários:

1. Campanhas de Conscientização e Benefícios Claros:

- **Acessibilidade:** Explique que a nuvem permite acessar arquivos de qualquer lugar, a qualquer hora, em qualquer dispositivo.
- **Colaboração:** Mostre como é fácil compartilhar documentos e trabalhar em equipe em tempo real, eliminando a necessidade de enviar anexos por e-mail.
- **Segurança e Backup:** Enfatize que os dados na nuvem corporativa são automaticamente copiados e protegidos contra perda (falha de hardware, roubo de dispositivo), ao contrário dos arquivos salvos apenas localmente.
- **Organização:** Demonstre como a nuvem pode ajudar a manter os arquivos organizados e fáceis de encontrar.

2. Treinamento Prático e Demonstrações:

- Ofereça workshops interativos e sessões de "mãos na massa" que mostrem como usar a plataforma de nuvem para tarefas diárias específicas da empresa.
- Crie "casos de uso" com exemplos reais de como a nuvem pode simplificar o trabalho deles.

- Mostre como a nuvem pode resolver problemas que eles enfrentam atualmente (ex: "como compartilhar um arquivo grande com um cliente sem usar e-mail?").

3. Canais de Suporte e Feedback:

- Crie um canal fácil para os usuários tirarem dúvidas e darem feedback sobre a plataforma. Isso ajuda a identificar e resolver barreiras de uso.

Medidas para Garantir a Implementação (Ações da Equipe de TI):

1. Definição de Políticas Claras de Uso:

- Estabeleça diretrizes sobre quais tipos de documentos *devem* ser armazenados na nuvem (ex: documentos de projeto, relatórios, planilhas colaborativas) e como devem ser organizados.
- Crie uma política de retenção de dados para a nuvem.

2. Integração com Fluxos de Trabalho Existentes:

- Se possível, integre a solução de nuvem com outras ferramentas que os usuários já utilizam (ex: sistemas de gestão de projetos, e-mail). Quanto mais transparente for a transição, melhor.

3. Migração Assistida e Obrigatória (para certos casos):

- Para departamentos ou projetos críticos, ofereça suporte para migrar os dados existentes para a nuvem.
- Considere tornar o armazenamento em nuvem obrigatório para novos projetos ou para documentos específicos, com um cronograma de transição.

4. Monitoramento e Análise de Uso:

- Monitore o uso da nuvem para identificar quais equipes ou usuários estão com dificuldades e ofereça suporte proativo.
- Analise os tipos de arquivos armazenados para entender as necessidades e adaptar o treinamento.

5. Implementação de DLP (Data Loss Prevention):

- Configure ferramentas de DLP para garantir que dados sensíveis não sejam armazenados em locais não aprovados (ex: nuvens pessoais não corporativas) e para incentivar o uso da nuvem corporativa como o local seguro e oficial.

6. Liderança pelo Exemplo:

- A própria equipe de TI e a liderança da empresa devem usar ativamente a nuvem e demonstrar seus benefícios.

b. Considerando que a empresa decidiu adotar uma política de senhas seguras para acesso ao sistema, utilizando letras maiúsculas, minúsculas e números, que outras recomendações você sugeriria para torná-las seguras por um período mais prolongado?

Essa é uma ótima base, meu bem, mas podemos ir muito além para garantir a segurança das senhas!

Recomendações Adicionais para Senhas Mais Seguras e Duradouras:

1. Comprimento Mínimo Aumentado:

- **Sugestão:** Além de maiúsculas, minúsculas e números, exija um comprimento mínimo maior, por exemplo, de 12 a 16 caracteres. Senhas mais longas são exponencialmente mais difíceis de quebrar por força bruta, mesmo que sejam mais simples em sua composição.

2. Uso de Caracteres Especiais:

- **Sugestão:** Torne obrigatório o uso de pelo menos um ou dois caracteres especiais (ex: !@#\$%^&*()_+~[]{}|;:~",.<>/?). Isso aumenta significativamente a complexidade da senha.

3. Histórico de Senhas:

- **Sugestão:** Implemente uma política que impeça a reutilização de senhas antigas. Por exemplo, o sistema deve lembrar as últimas 5 a 10 senhas usadas pelo usuário e não permitir que ele as utilize novamente.

4. Autenticação de Dois Fatores (2FA/MFA - Multi-Factor Authentication):

- **Sugestão:** Esta é a medida mais crucial! Exija a autenticação de dois fatores para acesso a todos os sistemas críticos. Mesmo que a senha seja comprometida, o

atacante ainda precisará de um segundo fator (como um código enviado para o celular, um token físico ou biometria) para acessar a conta.

5. Incentivo a Frases-Senha (Passphrases):

- **Sugestão:** Eduque os usuários sobre o conceito de frases-senha. Em vez de uma senha complexa e difícil de lembrar (ex: A1b@3C\$5), incentive o uso de uma frase longa e fácil de memorizar, mas difícil de adivinhar (ex: EuAmoMeuGatoPreto123!). Elas são longas e contêm diversos tipos de caracteres, sendo muito seguras.

6. Gerenciadores de Senhas Corporativos:

- **Sugestão:** Recomende e, se possível, forneça uma solução de gerenciamento de senhas corporativa. Isso permite que os usuários criem e armazenem senhas complexas e únicas para cada serviço sem precisar memorizá-las, além de facilitar o compartilhamento seguro de credenciais entre equipes (quando necessário).

7. Bloqueio de Conta por Tentativas Falhas:

- **Sugestão:** Configure os sistemas para bloquear uma conta após um número limitado de tentativas de login falhas (ex: 3 a 5 tentativas). Isso mitiga ataques de força bruta e adivinhação de senhas.

8. Conscientização e Treinamento Contínuo:

- **Sugestão:** Realize treinamentos regulares sobre a importância da segurança de senhas, como criar senhas fortes, os perigos do phishing e a importância de não compartilhar senhas. A educação é uma das defesas mais fortes.

Ao implementar essas medidas, as senhas se tornarão muito mais robustas e as contas dos usuários estarão significativamente mais protegidas contra acessos não autorizados, meu bem.